

FinWallet API Rehberi

Public giriş noktası

Normal client yalnız Gateway'i çağırır:

`http://localhost:8080`

Ana business prefix: `/api/v1`.

Anonymous Gateway rotaları:

- `POST /api/v1/auth/register`
- `POST /api/v1/auth/registration/verify`
- `POST /api/v1/auth/login`
- `POST /api/v1/auth/refresh`

Diğer `/api/*` rotaları Gateway'de JWT ister. FinWallet.Api `JWT/authorization/ownership` kontrolünü ayrıca tekrar yapar.

Ortak HTTP contract

Tüm success/failure body'leri `ServiceResult<T>` kullanır. Client logic sırası:

- 1 HTTP status;
- 2 stabil code.

Human-readable message business logic için parse edilmemelidir.

Correlation

Client X-Correlation-Id gönderebilir. Shared web platform yalnız bounded alphanumeric`/-/_` formatını kabul eder; geçersiz veya eksik değer yerine yeni ID üretir. Correlation ID transaction veya idempotency key değildir ve PII içermemelidir.

Authentication

Protected endpoint:

`Authorization: Bearer <access-token>`

JWT Gateway ve FinWallet.Api'de doğrulanır. Para değiştiren transfer akışı ayrıca JWT sid değerini durable CustomerSession ile kontrol eder.

Swagger

Development:

Gateway	<code>http://localhost:8080/swagger</code>
FinWallet.Api	<code>http://localhost:8081/swagger</code>
FakeBank.Api	<code>http://localhost:8082/swagger</code>
FakeFraud.Api	<code>http://localhost:8083/swagger</code>
FakeCutoff.Api	<code>http://localhost:8084/swagger</code>
FakeCampaign.Api	<code>http://localhost:8085/swagger</code>
FakeCommunication	<code>http://localhost:8086/swagger</code>

Production'da Swagger varsayılan kapalıdır.

Auth endpointleri

****Register**** — `POST /api/v1/auth/register` Pending customer oluşturur ve OTP'yi FakeCommunication'a gönderir. Başarı: HTTP 202.

****Verify**** — POST /api/v1/auth/registration/verify OTP verify+consume yapar ve customer'ı aktive eder.

****Login**** — POST /api/v1/auth/login Credential doğrular, durable session, access token ve refresh token üretir.

****Refresh**** — POST /api/v1/auth/refresh Opaque refresh token rotation yapar; token single-use'dur ve reuse detection session family revoke eder.

****Logout**** — henüz public endpoint olarak uygulanmadı.

Wallet endpointleri

****POST /api/v1/wallets**** — JWT gerekir.

```
{ "currency": "TRY" }
```

Desteklenen currency: TRY, USD, EUR. İlk create 201, aynı customer/currency tekrarında mevcut wallet 200 döner. Yeni wallet sıfır available/blocked balance ile başlar.

****GET /api/v1/wallets**** — JWT subject'e ait wallet'ları listeler.

Bank account

****POST /api/v1/bank-accounts**** — JWT gerekir.

```
{ "walletId": "<wallet-guid>" }
```

Akış:

```
Gateway JWT
-> API JWT + ownership
-> durable BankAccount(Opening)
-> SQL tamamlanır
-> Gateway /providers/bank/*
-> FakeBank
-> provider result validation
-> CAS state update
```

External HTTP açık SQL transaction içinde çalışmaz.

Wallet transfer

****POST /api/v1/transfers**** gerekir:

- JWT;
- active durable session;
- Idempotency-Key;
- owned/active source wallet;
- distinct active destination;
- aynı currency;
- positive/bounded amount;
- final fraud Allow;
- yeterli bakiye.

```
POST /api/v1/transfers
Authorization: Bearer <JWT>
Idempotency-Key: transfer-000001
Content-Type: application/json
```

```
{
  "sourceWalletId": "aaaaaaaa-1111-4111-8111-111111111111",
  "destinationWalletId": "bbbbbbbbb-2222-4222-8222-222222222222",
  "amount": 125.50
}
```

Sıra:

```
completed replay
-> session/risk
-> internal fraud
-> FakeFraud via Gateway
-> combined decision
-> atomic MSSQL posting
```

Completed replay aynı immutable transaction'ı döndürür; ikinci fraud evaluation veya ikinci money movement yapılmaz.

Funding durumu

Public BankDeposit endpoint'i henüz yoktur. Yeni wallet 0 bakiye ile açıldığı için register'dan sonra public endpointlerle kaynak wallet'ı fonlayıp transfer etmek mümkün değildir. Test fixture doğrudan balance UPDATE etmemeli; balanced FinancialTransaction + LedgerJournal/Entries oluşturmalıdır.

Internal/provider rotaları

```
/providers/bank/*
/providers/fraud/*
/providers/cutoff/*
/providers/campaign/*
/providers/communication/*
```

Bunlar public client API değildir. Gateway internal-service authorization ister; destination business endpoint ayrıca downstream service key doğrular.

Platform hata örnekleri

- JWT yok/geçersiz: 401 GATEWAY_UNAUTHORIZED.
- Direct backend without downstream key: 401 INTERNAL_SERVICE_UNAUTHORIZED.
- Rate limit: 429 RATE_LIMITED.
- Unsupported write content type: 415.
- TRACE/CONNECT: 405.
- Body/header limit aşımı: business processing başlamadan reddedilir.